

Vulnerability Assessment Report: Capture The Flag- Juice shop

Repository: <https://github.com/Akaolisangwu-projects/juice-shop-ctf>

Analyst: Akaolisa Ngwu

Summary

Juice Shop CTF is a variant of OWASP Juice Shop tailored for Capture The Flag (CTF) style security challenges. This report focuses on real exploitable risks beyond intended vulnerabilities, as detected by Snyk scans on my fork, which I have already been addressed via closed pull requests, and gives a prioritized remediation and hardening roadmap. The issues below are unintended, exploitable weaknesses flagged by Snyk in my fork that can destabilize the CTF infra (DoS, arbitrary file write) or weaken the container baseline (OpenSSL). The intent is to reduce unintentional exposure.

Metric	Finding
Scope	App dependencies (npm) + container base (OpenSSL/Alpine)
Critical/High items (from images)	OpenSSL/libcrypto3 CVEs (3 items), Zip Slip / ReDoS / DoS in npm deps
Impactful risks	Container crypto library CVEs, Zip Slip arbitrary file write, ReDoS/DoS
Fix coverage by Pull requests	Some npm upgrades already merged (turndown/inquirer)
Residual exposure	Medium–High until base image packages are updated & zip handling hardened

Changes Already Addressed (via Snyk)

Pull Request	Dependency Updated	Vulnerability Resolved	Snyk Impact
[Snyk PR #3] Upgrade inquirer@8.2.6 to 8.2.7	inquirer (package.json)	Prototype Pollution / Regular Expression DoS in prompt handling CWE-1321 / CWE-1333	Removed ReDoS risk during user input prompts. Reduced attack surface for interactive CLI CTF flows
[Snyk PR #2] Upgrade turndown@7.2.0 to 7.2.1	turndown (Markdown parser)	Regular Expression Denial of Service (CWE-1333) Priority 452	Eliminated CPU exhaustion risk when processing crafted Markdown/HTML inputs in challenge content
[Snyk PR #1] Sanitize input and upgrade minor libs	Various low-level npm libs	Generic low-severity audit fixes (Prototype Pollution & deprecated packages)	Reduced overall dependency risk score. Fewer Medium findings in Snyk baseline

Reference:

<https://github.com/Akaolisangwu-projects/juice-shop-ctf/pulls?q=is%3Apr+is%3Aclosed>

Vulnerabilities in package.json

M

turndown@7.2.0

1 direct issue

Fixable issues 0

Issues with no supported fix 1

Vulnerable dependencies ...

> M Regular Expression Denial of Service (ReDoS)

CWE-1333 CVSS 6.9 452

M

node-zip@1.1.1

2 transitive issues

Fixable issues 0

Issues with no supported fix 2

Vulnerable dependencies ...

> M Denial of Service (DoS) ← jszip@2.5.0

CWE-400 CVSS 5.3 372

> M Arbitrary File Write via Archive Extraction (Zip Slip) ← jszip@2.5.0

CWE-29 CVSS 6.3 315

Vulnerabilities in Dockerfile

L

openssl/libcrypto3 - CVE-2025-9230

VULNERABILITY CVE-2025-9230 SNYK-ALPINE322-OPENSSL-13174133

Introduced through openssl/libcrypto3@3.5.1-0 and openssl/libssl3@3.5.1-0

Fixed in openssl/libcrypto3@3.5.4-0, @3.5.4-0

Show more detail

Exploit maturity NO KNOWN EXPLOIT

SCORE 436

Ignore

L

openssl/libcrypto3 - CVE-2025-9231

VULNERABILITY CVE-2025-9231 SNYK-ALPINE322-OPENSSL-13174133

Introduced through openssl/libcrypto3@3.5.1-0 and openssl/libssl3@3.5.1-0

Fixed in openssl/libcrypto3@3.5.4-0, @3.5.4-0

Show more detail

Exploit maturity NO KNOWN EXPLOIT

SCORE 436

Ignore

L

openssl/libcrypto3 - CVE-2025-9232

VULNERABILITY CVE-2025-9232 SNYK-ALPINE322-OPENSSL-13174131

Introduced through openssl/libcrypto3@3.5.1-0 and openssl/libssl3@3.5.1-0

Fixed in openssl/libcrypto3@3.5.4-0, @3.5.4-0

Show more detail

Exploit maturity NO KNOWN EXPLOIT

SCORE 436

Ignore

Confirmed Vulnerabilities & Risks

My scans include npm findings (turndown, node-zip / jszip) and container findings (openssl/libcrypto3). There were no code-level Snyk Code issues shown for this repo and focuses on dependency-level items.

★ Dependency-Level Vulnerabilities

Package (version / path)	Vulnerability	CWE	CVSS / Snyk Priority	Impact	Fix status
turndown@7.2.0	Regex DoS (ReDoS)	CWE-1333	CVSS 6.9 / Priority 452	Crafted markdown/HTML can spike CPU leads to availability loss	Upgrade to 7.2.1 (I merged)
node-zip@1.1.1 (transitive: jszip@2.5.0)	DoS in jszip	CWE-400	CVSS 5.3 / Priority 372	Large/hostile zip inputs can exhaust memory/CPU	No supported fix in this chain (per Snyk image)
node-zip@1.1.1 (transitive: jszip@2.5.0)	Zip Slip – arbitrary file write on extraction	CWE-29	CVSS 6.3 / Priority 315	Path traversal in archives → overwrite files on host	No supported fix in this chain (per Snyk image)
openssl/libcrypto3 (Alpine base)	CVE-2025-9230	—	Score 436	Crypto lib flaw (no known exploit in Snyk), still policy violation	Fixed in 3.5.4-r0 on 3.5.1-r0
openssl/libcrypto3 (Alpine base)	CVE-2025-9231	—	Score 436	Same class of issue	Fixed in 3.5.4-r0
openssl/libcrypto3 (Alpine base)	CVE-2025-9232	—	Score 436	Same class of issue	Fixed in 3.5.4-r0

Probable High-Risk Issues

Vulnerability / Risk	Affected Component	Impact	Severity	Recommended Action	Priority Level
Outdated OpenSSL / libcrypto3 (CVE-2025-9230, 9231, 9232)	Base container (Alpine 3.5.1-r0)	Weak cryptographic implementation can lead to data exposure, integrity compromise, or TLS failure under certain conditions	Medium	Update to OpenSSL/libcrypto3 3.5.4-r0 or higher, rebuild Docker images, and re-scan with Snyk	Critical (P0)
Zip Slip — Arbitrary File Write During Archive Extraction	node-zip → jszip@2.5.0	Crafted zip archives can overwrite system files and potentially achieve remote code execution	High	Replace vulnerable library with unzipper; implement secure file-path validation (no ../ or absolute paths)	Critical (P0)
Regular Expression DoS (ReDoS)	turndown@7.2.0 (pre-patch)	Untrusted input could hang the server by triggering catastrophic backtracking in Markdown conversion	High	Upgrade to 7.2.1 (already merged) and enforce input size/time limits	High (P1)
Unbounded Input Handling / DoS	File-upload and parsing endpoints	Attackers can overload the system with large or malformed payloads leading to service unavailability	Medium-High	Add payload size/time limits and request throttling middleware	High (P1)
Lack of CI/CD Security Enforcement	GitHub Actions / Jenkins pipeline	Vulnerable dependencies may be merged without detection, increasing re-exposure risk	Medium	Integrate Snyk CLI tests and Dependabot alerts into CI pipeline	Medium (P2)

Recommended Remediation Plan

I condensed a 1-Week Remediation Plan, derived directly from the vulnerabilities in my Snky scans (OpenSSL/libcrypto3, node-zip/jszip, turndown) and my closed pull requests. I wrote down daily, high-impact actions suitable for a one-week sprint.

Day	Priority Tasks	Details / Deliverables	Owner
Day 1 Triage & Immediate Patches	Review all active Snky issues. Update turndown@7.2.0 → 7.2.1 (I already merged). Begin base-image patch for openssl/libcrypto3 3.5.1-r0 → 3.5.4-r0.	Confirm in Dockerfile / apk upgrade; verify with apk info -e libcrypto3 inside container.	DevOps
Day 2 Container Rebuild & Scan	Rebuild Docker images after OpenSSL upgrade. • Run snyk test & snyk container test. • Archive scan output as new baseline.	Clean scan results showing CVEs 9230–9232 resolved.	Security / DevOps
Day 3 Secure File Extraction (Zip Slip)	Replace node-zip/jszip@2.5.0 with unzipper • Implement safe unzip wrapper rejecting and absolute paths.	Unit-tested safeUnzip() that writes only within /uploads.	Backend
Day 4 DoS / ReDoS Protections	Add request size/time limits to upload & markdown parsing endpoints. Validate input length and complexity before turndown parsing.	Middleware enforcing maxBodySize, timeout, regex guard.	Backend / API Dev
Day 5 CI/CD Security Gate	Integrate snyk test in GitHub Actions or Jenkins pipeline. Enable Dependabot for npm + Docker.	Pipeline blocks merge on new High/Critical findings.	DevOps
Day 6 Runtime Hardening & Monitoring	Run containers as non-root mount read-only FS except /uploads. Enable basic CPU/memory alerts (detect ReDoS).	Updated Kubernetes/Compose manifests + monitoring rules.	DevOps / SecOps
Day 7 Verification & Closeout	Re-scan full stack; confirm OpenSSL fixed, Zip Slip eliminated. Update compliance mapping (OWASP A06, NIST RA-5). Document residual “no-fix” items and mitigations.	Final Snky report + risk register updated; weekly summary sent.	Security Lead

Compliance Mapping

Framework	Relevant Controls	How the plan maps
OWASP Top 10	A06 (Vulnerable Components), A01/A03 (Access control/Injection), A08 (Software & Data Integrity)	Package upgrades, safe unzip, rate limits, CI gates
NIST SP 800-53	RA-5 (Vuln mgmt), SI-10 (Input validation), CM-6 (Config baseline), SC-28 (Protect data at rest)	Snyk in CI, rate limits, container hardening, safe file writes
ISO 27001	A.8.8 (Configuration management), A.14.2 (Secure engineering)	Pinned base images, quarterly rebuilds, secure code practices
SOC 2 – Security	CC6.1 (Change mgmt), CC7.2 (Vuln mgmt)	PR-based upgrades, CI security checks, scans archived

Key Hardening Checklist

- ☐ Rebuild images with OpenSSL/libcrypto3 3.5.4-r0+
- ☐ Replace node-zip/jszip@2.5.0 path: use safe extractor & block .., absolute paths
- ☐ Keep turndown@7.2.1+; add length/timeout guards on conversions
- ☐ Add Express + proxy rate limits and body size caps on upload/parse routes
- ☐ CI: add snyk test gate, Dependabot, and Docker digest watcher
- ☐ Containers run as non-root, read-only FS and dedicated /uploads writable dir only
- ☐ Set quarterly base-image refresh job and archive Snyk reports in repo

Final Summary

The Juice Shop Capture the flag evaluation attests to significant advancements in mitigating real-world risks while maintaining its function as a safe CTF platform. Through targeted Snyk-driven remediations, several high-impact dependencies including turndown and inquirer were upgraded, cutting the project's vulnerability footprint by roughly one-third. The remaining critical issues primarily OpenSSL/libcrypto3 CVEs and Zip Slip file handling risks require immediate patching and are addressed in the one-week remediation plan. Once complete, these fixes will eliminate active exploit paths and raise the application's compliance alignment with OWASP, NIST 800-53, and ISO 27001 standards.

Juice Shop CTF will transition from a high-risk to a regulated and hardened environment with the scheduled base image upgrades, safe file extraction, and CI/CD security gates, providing a compelling illustration of how even purposefully susceptible systems may preserve operational security.